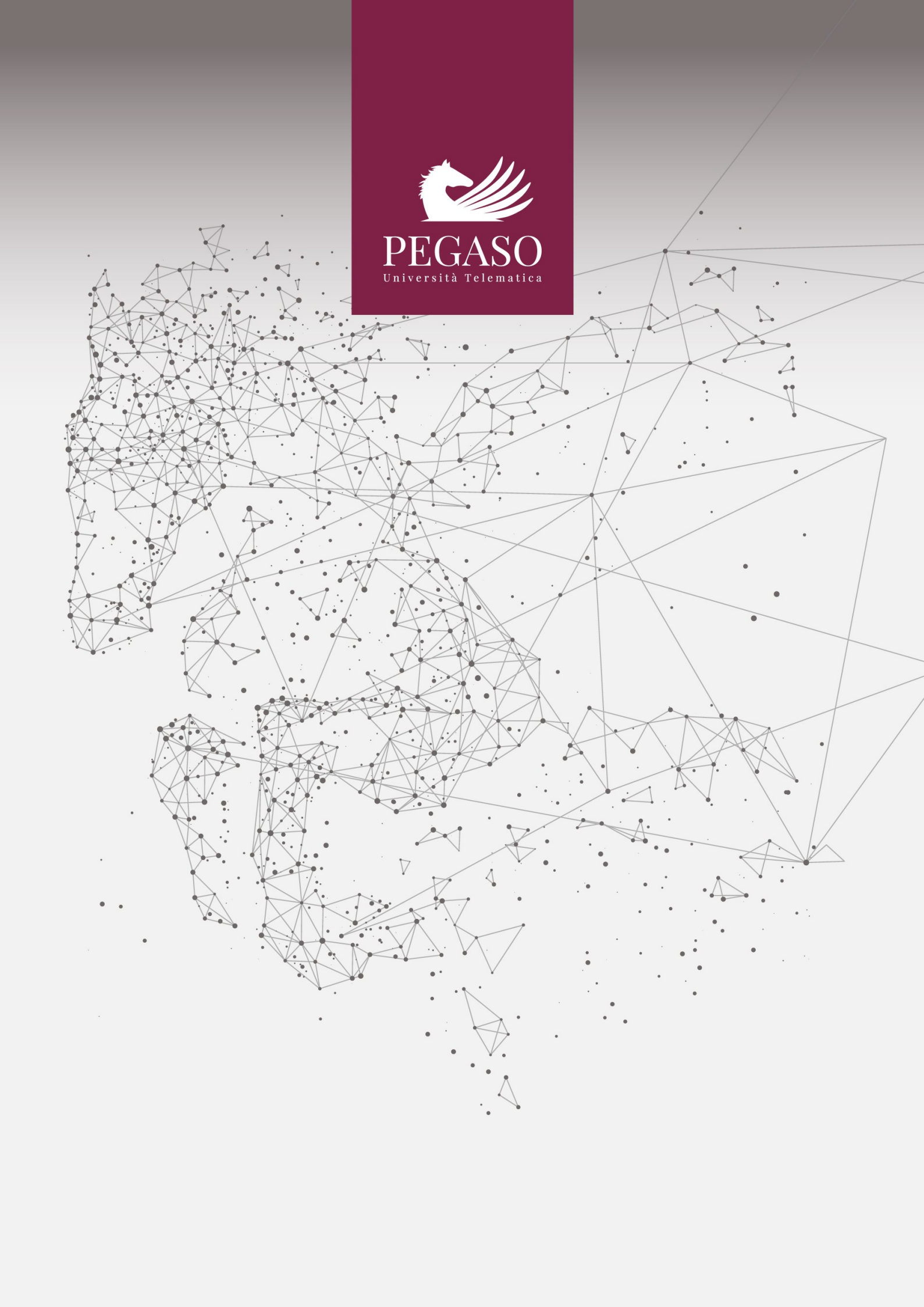

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 COS'È IL "DATA BREACH"?I 3

2 COME VALUTARE SE SI È IN PRESENZA DI UN "DATA BREACH"? 9

3 PROCEDURE E ADEMPIMENTI 11

BIBLIOGRAFIA 15

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Cos'è il "data breach"?I

Il "data breach" è una violazione di sicurezza che comporta:

- la distruzione,
- la perdita,
- la modifica,
- la divulgazione non autorizzata, o
- l'accesso

ai dati personali trasmessi, conservati o comunque trattati. Non è necessario che vi sia un intento illecito o fraudolento: può avvenire anche accidentalmente, ad esempio per negligenza di un dipendente o per un caso fortuito come un corto circuito che distrugge un archivio informatico.

Il Regolamento UE 679/2016 (GDPR) contiene una disciplina piuttosto dettagliata per questo tipo di eventi. L'articolo 4 del GDPR fornisce al numero 12 una definizione di data breach:

> *«violazione dei dati personali»: la violazione di sicurezza che comporta accidentalmente o in modo illecito la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso ai dati personali trasmessi, conservati o comunque trattati.*

Le procedure da seguire nel caso in cui avvenga una violazione dei dati personali sono invece delineate negli articoli 33 e 34 del GDPR. L'articolo 33, rubricato "Notifica di una violazione dei dati personali all'autorità di controllo", dispone:

> *1. In caso di violazione dei dati personali, il titolare del trattamento notifica la violazione all'autorità di controllo competente a norma dell'articolo 55 senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui ne è venuto a conoscenza, a meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche. Qualora la notifica all'autorità di controllo non sia effettuata entro 72 ore, è corredata dei motivi del ritardo.*

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Il responsabile del trattamento informa il titolare del trattamento senza ingiustificato ritardo dopo essere venuto a conoscenza della violazione.

3. La notifica di cui al paragrafo 1 deve almeno:

a) descrivere la natura della violazione dei dati personali compresi, ove possibile, le categorie e il numero approssimativo di interessati in questione nonché le categorie e il numero approssimativo di registrazioni dei dati personali in questione;

b) comunicare il nome e i dati di contatto del responsabile della protezione dei dati o di altro punto di contatto presso cui ottenere più informazioni;

c) descrivere le probabili conseguenze della violazione dei dati personali;

d) descrivere le misure adottate o di cui si propone l'adozione da parte del titolare del trattamento per porre rimedio alla violazione dei dati personali e anche, se del caso, per attenuarne i possibili effetti negativi.

4. Qualora e nella misura in cui non sia possibile fornire le informazioni contestualmente, le informazioni possono essere fornite in fasi successive senza ulteriore ingiustificato ritardo.

5. Il titolare del trattamento documenta qualsiasi violazione dei dati personali, comprese le circostanze a essa relative, le sue conseguenze e i provvedimenti adottati per porvi rimedio. Tale documentazione consente all'autorità di controllo di verificare il rispetto del presente articolo.

Ai sensi dell'articolo 34 del GDPR, che disciplina la "Comunicazione di una violazione dei dati personali all'interessato":

1. Quando la violazione dei dati personali è suscettibile di presentare un rischio elevato per i diritti e le libertà delle persone fisiche, il titolare del trattamento comunica la violazione all'interessato senza ingiustificato ritardo.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. La comunicazione all'interessato di cui al paragrafo 1 del presente articolo descrive con un linguaggio semplice e chiaro la natura della violazione dei dati personali e contiene almeno le informazioni e le misure di cui all'articolo 33, paragrafo 3, lettere b), c) e d).

3. Non è richiesta la comunicazione all'interessato di cui al paragrafo 1 se è soddisfatta una delle seguenti condizioni:

a) il titolare del trattamento ha messo in atto le misure tecniche e organizzative adeguate di protezione e tali misure erano state applicate ai dati personali oggetto della violazione, in particolare quelle destinate a rendere i dati personali incomprensibili a chiunque non sia autorizzato ad accedervi, quali la cifratura;

b) il titolare del trattamento ha successivamente adottato misure atte a scongiurare il sopraggiungere di un rischio elevato per i diritti e le libertà degli interessati di cui al paragrafo 1;

c) detta comunicazione richiederebbe sforzi sproporzionati. In tal caso, si procede invece a una comunicazione pubblica o a una misura simile, tramite la quale gli interessati sono informati con analoga efficacia.

4. Nel caso in cui il titolare del trattamento non abbia ancora comunicato all'interessato la violazione dei dati personali, l'autorità di controllo può richiedere, dopo aver valutato la probabilità che la violazione dei dati personali presenti un rischio elevato, che vi provveda o può decidere che una delle condizioni di cui al paragrafo 3 è soddisfatta.

Come si evince dalla normativa, dunque, tutti i titolari del trattamento sono tenuti a notificare alla competente Autorità di controllo entro termini definiti le violazioni di dati personali suscettibili di presentare un rischio elevato per i diritti e le libertà delle persone fisiche. Tale obbligo di notifica è

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

simile a quanto veniva prescritto dall' articolo 32*bis* del Codice Privacy abrogato con il decreto legislativo 101/2018[1].

Alcuni esempi di data breach sono:

- Accesso o acquisizione dei dati da parte di terzi non autorizzati;
- Deliberata alterazione di dati personali;

[1] *1. In caso di violazione di dati personali, il fornitore di servizi di comunicazione elettronica accessibili al pubblico comunica senza indebiti ritardi detta violazione al Garante.*

2. Quando la violazione di dati personali rischia di arrecare pregiudizio ai dati personali o alla riservatezza di contraente o di altra persona, il fornitore comunica anche agli stessi senza ritardo l'avvenuta violazione.

3. La comunicazione di cui al comma 2 non è dovuta se il fornitore ha dimostrato al Garante di aver utilizzato misure tecnologiche di protezione che rendono i dati inintelligibili a chiunque non sia autorizzato ad accedervi e che tali misure erano state applicate ai dati oggetto della violazione.

4. Ove il fornitore non vi abbia già provveduto, il Garante può, considerate le presumibili ripercussioni negative della violazione, obbligare lo stesso a comunicare al contraente o ad altra persona l'avvenuta violazione.

5. La comunicazione al contraente o ad altra persona contiene almeno una descrizione della natura della violazione di dati personali e i punti di contatto presso cui si possono ottenere maggiori informazioni ed elenca le misure raccomandate per attenuare i possibili effetti pregiudizievoli della violazione di dati personali. La comunicazione al Garante descrive, inoltre, le conseguenze della violazione di dati personali e le misure proposte o adottate dal fornitore per porvi rimedio.

6. Il Garante può emanare, con proprio provvedimento, orientamenti e istruzioni in relazione alle circostanze in cui il fornitore ha l'obbligo di comunicare le violazioni di dati personali, al formato applicabile a tale comunicazione, nonché alle relative modalità di effettuazione, tenuto conto delle eventuali misure tecniche di attuazione adottate dalla Commissione europea ai sensi dell'articolo 4, paragrafo 5, della direttiva 2002/58/CE, come modificata dalla direttiva 2009/136/CE.

7. I fornitori tengono un aggiornato inventario delle violazioni di dati personali, ivi incluse le circostanze in cui si sono verificate, le loro conseguenze e i provvedimenti adottati per porvi rimedio, in modo da consentire al Garante di verificare il rispetto delle disposizioni del presente articolo. Nell'inventario figurano unicamente le informazioni necessarie a tal fine.

8. Nel caso in cui il fornitore di un servizio di comunicazione elettronica accessibile al pubblico affidi l'erogazione del predetto servizio ad altri soggetti, gli stessi sono tenuti a comunicare al fornitore senza indebito ritardo tutti gli eventi e le informazioni necessarie a consentire a quest'ultimo di effettuare gli adempimenti di cui al presente articolo.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Impossibilità di accedere ai dati (per cause accidentali o attacchi esterni, virus, malware…);
- Perdita o distruzione di dati personali;
- Furto o perdita di dispositivi informatici contenenti dati personali;
- Divulgazione non autorizzata dei dati personali.

Per quanto riguarda la valutazione sulla necessità di notificare la violazione dei dati all'Autorità garante e all'interessato, l'elemento discriminante è il rischio che tale data breach crea per l'interessato; questo rischio può concretizzarsi nella distruzione, nella perdita, nella modifica, nella divulgazione non autorizzata o nell'accesso illegale ai dati personali. Rilevante in questo senso è il considerando 75:

CONSIDERANDO 75: "*I rischi per i diritti e le libertà delle persone fisiche, aventi probabilità e gravità diverse, possono derivare da trattamenti di dati personali suscettibili di cagionare un danno fisico, materiale o immateriale, in particolare: se il trattamento può comportare discriminazioni, furto o usurpazione d'identità, perdite finanziarie, pregiudizio alla reputazione, perdita di riservatezza dei dati personali protetti da segreto professionale, decifratura non autorizzata della pseudonimizzazione, o qualsiasi altro danno economico o sociale significativo; se gli interessati rischiano di essere privati dei loro diritti e delle loro libertà o venga loro impedito l'esercizio del controllo sui dati personali che li riguardano; se sono trattati dati personali che rivelano l'origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, l'appartenenza sindacale, nonché dati genetici, dati relativi alla salute o i dati relativi alla vita sessuale o a condanne penali e a reati o alle relative misure di sicurezza; in caso di valutazione di aspetti personali, in particolare mediante l'analisi o la previsione di aspetti riguardanti il rendimento professionale, la situazione economica, la salute, le preferenze o gli interessi personali, l'affidabilità o il comportamento, l'ubicazione o gli spostamenti, al fine di creare o utilizzare profili personali; se sono trattati dati personali di persone fisiche vulnerabili, in particolare minori; se il trattamento riguarda una notevole quantità di dati personali e un vasto numero di interessati.*"

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Le violazioni di dati personali possono essere suddivise in tre diverse tipologie:

1. Violazione della riservatezza: avviene quando vi sia una divulgazione dei dati personali o un accesso non autorizzato o accidentale;
2. Violazione dell'integrità: nei casi di modifica non autorizzata o accidentale dei dati personali;
3. Violazione della disponibilità: quando vi sia la perdita, l'accesso o la distruzione accidentale o non autorizzata dei dati personali.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Come valutare se si è in presenza di un "data breach"?

Quando si verificano eventi che comportino quale effetto una delle violazioni indicate (e dunque: in caso di perdita della disponibilità dei dati, violazione della loro riservatezza o della loro integrità), si è in presenza di un data breach ai sensi di quanto indicato dal GDPR.

L'effettiva gravità della violazione può variare e ripercuotersi con diversa intensità sui diritti e le libertà degli individui, indipendentemente dal tipo di evento che l'ha causata e in relazione al contesto in cui si verifica: ad esempio, la perdita di una chiavetta usb contenente dei dati personali assume diversa gravità se si tratta di dati sanitari di pazienti di un grosso ospedale o dati identificativi di clienti di una piccola impresa raccolti per finalità di marketing. Ad ogni modo, indipendentemente dalla gravità, si è comunque in presenza di una violazione dei dati personali cui conseguono determinati obblighi.

Per valutare se si è in presenza di un data breach e come procedere, possiamo utilizzare un semplice schema di valutazione, riportato nell'esempio seguente:

- ✓ Tipo di breach: distruzione.
- ✓ Definizione: un insieme di dati personali che a seguito di incidente o azione fraudolenta, non è più nella disponibilità del titolare, né di altri; in caso di richiesta del dato da parte dell'interessato non sarebbe possibile produrlo.
- ✓ Estensione minima/ soglia di segnalazione: dati non recuperabili o provenienti da procedure non ripetibili; rientrano tra i casi di segnalazione i soli dati appartenenti a documenti definitivi e già contrassegnati da un livello minimo di validazione.
- ✓ Esempi: guasto non riparabile dell'hard disk contenente uno o più referti che, in violazione al regolamento, erano salvati localmente; rottura di una chiavetta USB o di un PC che non contiene dati personali originali (in unica copia).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Il Garante per la protezione dei dati personali, nella pagina sul sito web relativa alla violazione di dati personali, risponde al quesito relativo a quali violazioni debbano essere notificate:

"*Vanno notificate unicamente le violazioni di dati personali che possono avere effetti avversi significativi sugli individui, causando danni fisici, materiali o immateriali.*

Ciò può includere, ad esempio, la perdita del controllo sui propri dati personali, la limitazione di alcuni diritti, la discriminazione, il furto d'identità o il rischio di frode, la perdita di riservatezza dei dati personali protetti dal segreto professionale, una perdita finanziaria, un danno alla reputazione e qualsiasi altro significativo svantaggio economico o sociale."

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Procedure e adempimenti

In caso di violazione, il titolare si trova di fronte a due possibili obblighi di notifica:

- All'Autorità garante, ai sensi dell'articolo 33 del GDPR;
- All'interessato, ex articolo 34 del GDPR, quando la violazione è suscettibile di presentare un rischio elevato per i diritti e le libertà delle persone fisiche.

Per quanto riguarda l'obbligo di notifica al Garante privacy previsto dall'articolo 33, di fronte a un data breach il titolare deve attuare una verifica sul rischio e, a meno che sia improbabile che la violazione ponga un serio rischio per le libertà e i diritti dei soggetti interessati, deve notificare il data breach all'Autorità garante entro 72 ore (e, comunque, senza ingiustificato ritardo). È possibile, nei casi particolarmente complessi, effettuare la notifica in ritardo, corredandola dei motivi che hanno impedito di rispettare il termine.

Se la violazione avviene nell'ambito dell'organizzazione del responsabile del trattamento, questi deve notificare tale evento al titolare, che procederà poi con la notifica al Garante nei casi opportuni.

Il considerando 87 stabilisce che:

CONSIDERANDO 87: "*È opportuno verificare se siano state messe in atto tutte le misure tecnologiche e organizzative adeguate di protezione per stabilire immediatamente se c'è stata violazione dei dati personali e informare tempestivamente l'autorità di controllo e l'interessato. È opportuno stabilire il fatto che la notifica sia stata trasmessa senza ingiustificato ritardo, tenendo conto in particolare della natura e della gravità della violazione dei dati personali e delle sue conseguenze e effetti negativi per l'interessato. Siffatta notifica può dar luogo a un intervento dell'autorità di controllo nell'ambito dei suoi compiti e poteri previsti dal presente regolamento*."

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Pubbliche amministrazioni e strutture sanitarie (pubbliche e private) hanno termini diversi e inferiori per effettuare la notifica del data breach: in generale devono provvedere entro 48 ore, che però sono ridotte a 24 quando vi sia un rischio di impatto significativo sui dati biometrici.

In ogni caso, non è necessario che il titolare disponga immediatamente di tutte le informazioni relative alla violazione: questi può anche procedere a una notifica in due fasi, la prima entro 72 ore contenente le informazioni disponibili, poi la seconda a seguito delle indagini per quanto riguarda i risultati delle stesse. Le notifiche da parte del titolare devono comunque essere effettuate senza ingiustificato ritardo.

Nelle "Linee guida sulla notifica delle violazioni dei dati personali ai sensi del regolamento (UE) 2016/679" del Gruppo di Lavoro Articolo 29 (WP29) nella loro versione emendata adottata il 6 febbraio 2018, sono contenute alcune considerazioni interessanti sull'obbligo di notifica da parte del titolare:

"*Il regolamento impone al titolare del trattamento di notificare una violazione senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui ne è venuto a conoscenza. Questo solleva la questione relativa al momento in cui il titolare del trattamento può considerarsi "a conoscenza" di una violazione. Il Gruppo di lavoro ritiene che il titolare del trattamento debba considerarsi "a conoscenza" nel momento in cui è ragionevolmente certo che si è verificato un incidente di sicurezza che ha portato alla compromissione dei dati personali.*

Tuttavia, come già osservato, il regolamento impone al titolare del trattamento di attuare tutte le misure tecniche e organizzative di protezione adeguate per stabilire immediatamente se si è verificata una violazione e informare tempestivamente l'autorità di controllo e gli interessati. Afferma altresì che è opportuno stabilire il fatto che la notifica sia stata trasmessa senza ingiustificato ritardo, tenendo conto in particolare della natura e della gravità della violazione e delle sue conseguenze e dei suoi effetti negativi per l'interessato. Il titolare del trattamento è quindi tenuto a prendere le misure necessarie per assicurarsi di venire "a conoscenza" di eventuali violazioni in maniera tempestiva in modo da poter adottare le misure appropriate.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Il momento esatto in cui il titolare del trattamento può considerarsi "a conoscenza" di una particolare violazione dipenderà dalle circostanze della violazione. In alcuni casi sarà relativamente evidente fin dall'inizio che c'è stata una violazione, mentre in altri potrebbe occorrere del tempo per stabilire se i dati personali sono stati compromessi. Tuttavia, l'accento dovrebbe essere posto sulla tempestività dell'azione per indagare su un incidente per stabilire se i dati personali sono stati effettivamente violati e, in caso affermativo, prendere misure correttive ed effettuare la notifica, se necessario."

Passando ora ad esaminare la comunicazione all'interessato, questa non è necessaria quando si verifichino le seguenti situazioni:

- Il titolare ha messo in atto misure tecniche e organizzative per proteggere i dati, ad esempio la cifratura degli stessi;
- Il titolare ha adottato misure atte a scongiurare il sopraggiungere di un rischio elevato;
- La comunicazione richiederebbe sforzi sproporzionati: in questi casi, il titolare può procedere a una comunicazione pubblica, ad esempio attraverso un post sul proprio sito web.

Negli altri casi, quando il titolare comunica il data breach all'interessato, deve utilizzare un linguaggio semplice e chiaro, descrivere la natura della violazione e fornire all'interessato almeno le stesse misure e informazioni indicate nella comunicazione al Garante.

Il contenuto della notifica, al Garante o all'interessato, è quindi necessariamente costituito da:

1. Descrizione della natura della violazione (compresi, ove possibile, le categorie e il numero approssimativo di interessati in questione nonché le categorie e il numero approssimativo di registrazioni dei dati personali in questione);
2. Nome e dati di contatto del Data Protection Officer;
3. Descrizione delle probabili conseguenze della violazione;

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4. Descrizione delle misure adottate (o che si intende adottare) per rimediare alla violazione.

Se necessario, il titolare del trattamento può fornire ulteriori informazioni (come, ad esempio, i dati di contatti del responsabile del trattamento).

Per inviare la notifica al Garante, il titolare può procedere tramite pec all'indirizzo protocollo@pec.gpdp.it, oppure tramite posta elettronica ordinaria all'indirizzo protocollo@gpdp.it. L'oggetto del messaggio deve contenere la dicitura "Notifica violazione dati personali", mentre è opzionale l'inserimento del nome del titolare.

La notifica deve essere sottoscritta digitalmente o con firma autografa corredata da una copia del documento d'identità.

Sul sito del Garante sono presenti sia uno strumento di autovalutazione sia un modello da compilare per la notifica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Gruppo di Lavoro Articolo 29, Linee guida sulla notifica delle violazioni dei dati personali ai sensi del regolamento (UE) 2016/679.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).